

MALLA DE SEGURIDAD, PRIVACIDAD Y RESILIENCIA

Sistema: Asesor Financiero IA

Orquestador: n8n

Marco Normativo de Referencia: GDPR / AI Act (2026)

1. Políticas de Minimización de Datos y Privacidad (Privacy by Design)

Siguiendo el principio de **Minimización de Datos** (*Data Minimization*) exigido por el RGPD y el marco regulatorio del AI Act (2026), el sistema implementa una arquitectura donde los datos personales no indispensables son interceptados y eliminados antes de interactuar con los motores de Inteligencia Artificial o almacenarse en bases de datos externas:

- **Sanitización del Payload de Entrada (Anti Data-Stuffing):**
El disparador de correo captura el extracto bancario en bruto, el cual contiene metadatos técnicos extensos, firmas digitales en base64 y código HTML pesado. Un nodo de transformación (**Set / Edit Fields**) depura el flujo inmediatamente, extrayendo únicamente tres variables esenciales en texto plano: `sender_email`, `subject` y `clean_statement_body`.
- **Enmascaramiento y Anonimización de Información Financiera Crítica (PII):**
Los números de tarjeta de crédito completos, códigos de seguridad (CVV) y direcciones postales del titular presentes en el encabezado del resumen bancario son eliminados del pipeline. El modelo de IA (**Claude 3.5 Sonnet**) solo recibe los últimos cuatro dígitos de la tarjeta (`card_last_four`) y el nombre del comercio junto con el importe.
- **Memoria Volátil y Destrucción de Datos Temporales:**
Los fragmentos del extracto bancario se procesan en la memoria volátil de ejecución de n8n. No se almacena ninguna copia persistente del archivo original en servidores de terceros una vez concluido el ciclo de inferencia y extracción de gastos.

2. Rutas de Contingencia y Tolerancia a Fallos (Error Handling en n8n)

Para garantizar que el ecosistema no experimente fallas silenciosas ni interrupciones abruptas ante caídas de red o saturación de APIs externas (*Rate Limits*), se configuraron rutas de contingencia estructuradas:

2.1 Directiva de Reintentos Automáticos (Modo Break)

- **Punto de Implementación:** Nodos de inferencia con LLM ([OpenAI Chat Model](#) y [Anthropic Chat Model](#)) y conectores de salida a APIs externas ([Slack API](#)).
- **Configuración del Reintento Inteligente:**
 - **Estrategia:** Reintento automático con retroceso exponencial (*Exponential Backoff*).
 - **Número de Intentos ([Attempts](#)):** 3 intentos consecutivos.
 - **Intervalo de Espera ([Interval](#)):** 15 segundos entre el intento 1 y 2; 45 segundos entre el intento 2 y 3.
- **Objetivo:** Mitigar micro-cortes de red, errores HTTP 500 (Server Error) o saturaciones temporales HTTP 429 (Too Many Requests) sin requerir reinicios manuales.

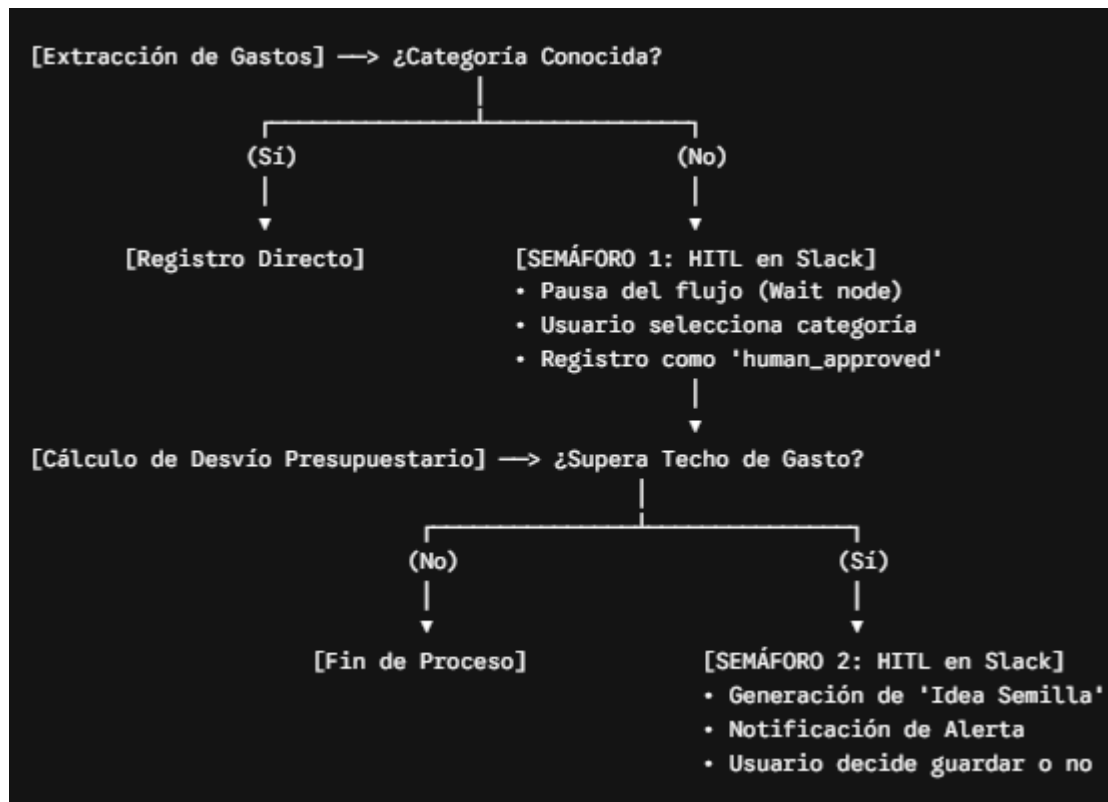
2.2 Auditoría Automática y Persistencia de Incidentes ([system_logs](#))

Si la API externa agota los 3 reintentos sin éxito:

1. El flujo no se detiene en estado de error fatal (*Workflow Crash*).
2. Se activa la rama de contingencia secundaria ([Error Trigger](#)), la cual captura el objeto de error retornado ([error_code](#), [error_message](#), [node_origin](#), [execution_id](#)).
3. Se inserta un registro inmediato en la tabla [system_logs](#) de [Airtable](#) marcando el incidente con estado [api_error](#) y [resolved: false](#).
4. Se despacha una alerta crítica a un canal interno de mantenimiento en Slack ([#alertas-sistema](#)) notificando al administrador para revisión asistida.

3. Semáforos de Validación Manual: Human-in-the-Loop (HITL)

Para erradicar el riesgo de alucinaciones de la IA y evitar el antipatrón del "Efecto Metrallera" (disparar alertas de gasto o modificaciones contables erróneas de forma descontrolada), el sistema introduce **dos puntos de pausa deliberados**:



Semáforo 1: Validación y Aprobación de Categorías No Reconocidas

- **Riesgo Mitigado:** Que la IA asigne incorrectamente un consumo atípico a un rubro que no le corresponde (por ejemplo, clasificar la compra de insumos de jardinería o herramientas como un gasto superfluo), distorsionando el cálculo de techos presupuestarios.
- **Mecanismo:**
 - Si el índice de confianza (*Confidence Score*) devuelto por la IA es menor a 0.80 o la descripción no coincide con ninguna categoría registrada, el gasto se guarda en Airtable con estado `pending_classification`.
 - n8n activa un nodo `Wait for Webhook` y envía una tarjeta interactiva a Slack (`#aprobaciones-gastos`) con los datos esenciales (monto, fecha, comercio) y botones con opciones sugeridas.
 - El flujo permanece en pausa hasta que el usuario hace clic y elige la categoría. Solo tras esa validación el gasto pasa a estado `human_approved` y se incluye en la suma consolidada.

Semáforo 2: Autorización para Guardar la "Idea Semilla" de Ahorro

- **Riesgo Mitigado:** Saturar al usuario con recomendaciones no deseadas o consejos que no se adaptan a su realidad operativa inmediata.
- **Mecanismo:**

- Cuando una categoría excede el 80% o supera el 100% de su límite mensual, Claude 3.5 Sonnet formula un diagnóstico y una recomendación táctica de ahorro personalizada.
- La recomendación se envía a Slack (`#alertas-presupuesto`) acompañada de un control de confirmación: *"¿Deseas guardar esta recomendación en tu lista de hábitos diarios?"*.
- Solo si el usuario confirma de forma explícita, el campo booleano `is_recommendation_saved` en Airtable pasa a `true`, asegurando que la IA proponga, pero el usuario siempre disponga.

4. Controles de Seguridad Lógica y Filtros Anti-Bucle

- **Filtro Anti Auto-Reply:** Inmediatamente después del trigger de Gmail, un nodo condicional determinista evalúa los encabezados del correo. Si el asunto contiene `Auto-reply`, `Out of Office`, `Undeliverable` o proviene de casillas `no-reply@`, el flujo se cancela en la rama `Stop / No Operation`, eliminando la posibilidad de bucles infinitos de procesamiento.
- **Tipado Estricto de Datos:** Los filtros lógicos y comparaciones matemáticas operan estrictamente sobre tipos numéricos validados (`amount_ars`, `monthly_limit_ars`), previniendo errores por comparación de cadenas de texto (`strings`) que impidan detectar desvíos reales de presupuesto.